

Production Hardening Report

Generated 2026-06-09 15:04

Executive Summary

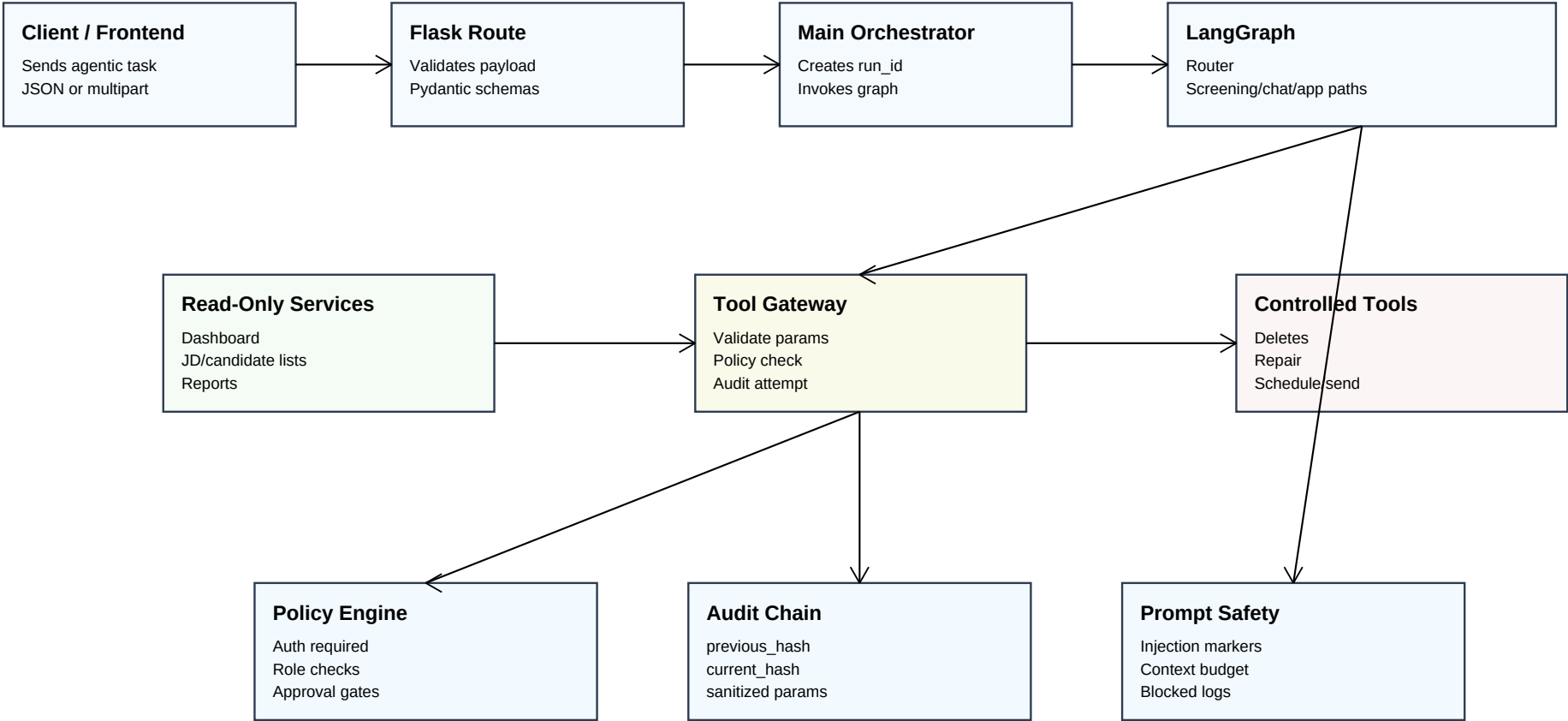
- The existing Flask, LangGraph, and MongoDB HR agent system was hardened without replacing the product workflow.
- The implementation adds typed validation, a policy-enforced tool gateway, tamper-evident audit logging, and prompt/context safety checks.
- The core recruitment graph remains intact: router, screening path, recruiter chat path, and app workflow path still use the same API surface.
- Controlled mutations now have a security boundary instead of being called directly from agents or workflows.

Design Intent

- Preserve working HR behavior while adding production safeguards around the riskiest operations.
- Prefer incremental hardening over a disruptive migration to FastAPI, MCP servers, or a new database stack.
- Make unsafe or ambiguous actions fail closed with clear approval-required or authorization-denied responses.

Updated Architecture

How the new controls fit around the existing LangGraph system



Key boundary: role agents can still decide what to do, but controlled side effects are executed only by the gateway.

Implementation Changes

Files and behavior added by the hardening pass

Validation Layer

- Added schemas/agent.py with Pydantic v2 models for agentic payloads and recruiter action params.
- Routes now validate /api/agent/run and /api/agent/screening before graph invocation.
- Invalid task types, missing IDs, malformed params, and missing files now return request validation errors earlier.

Gateway and Policy

- Added tools/tool_gateway.py with ToolRequest, ToolResult, and registered controlled tool handlers.
- Added security/policy.py with role checks, approval gates, auth requirements, and bulk-write protection.
- App workflow now routes JD create/delete, candidate delete/repair, interview schedule, and profile update through the gateway.

Audit and Prompt Safety

- database.log_audit now supports run_id, tool, outcome, sanitized params, previous_hash, and current_hash.
- Added verify_audit_chain() for tamper-evident audit validation.
- Router and recruiter chat now run lightweight prompt-injection checks before LLM calls.

Behavioral Understanding

What changed at runtime

Controlled Action Rules

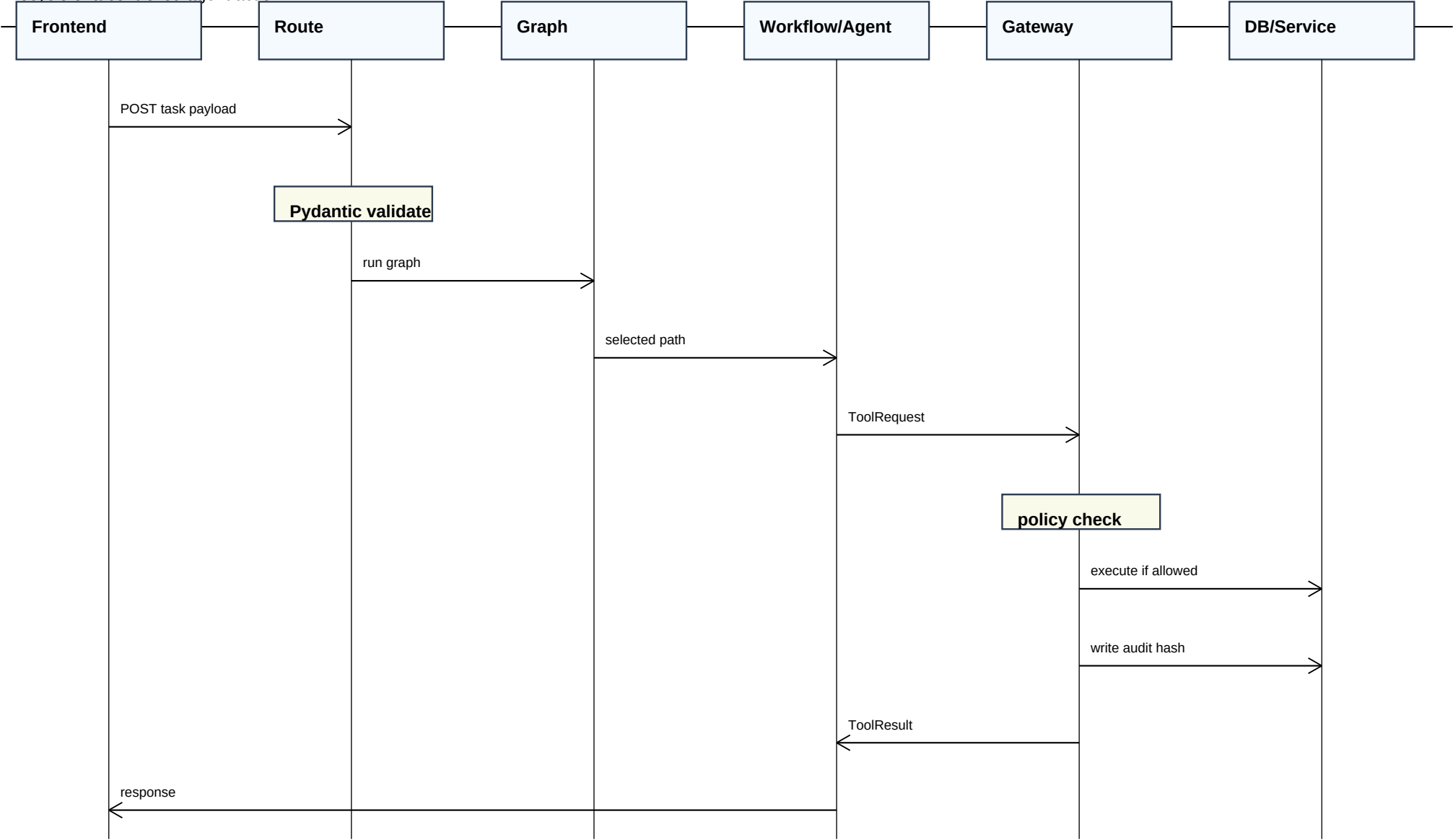
- Deletes require a manager/admin-style role and explicit confirmation.
- Candidate repair, interview scheduling, email sending, password changes, and bulk writes over 50 rows require explicit confirmation.
- If approval is missing, the tool is not executed and the response says approval is required.
- If authorization fails, the tool is not executed and the response says the action is not allowed.
- Every gateway attempt is audited as allowed, denied, approval_required, or failed.

Prompt and Context Safety

- Recruiter chat still uses compact grounded context, but the context is now trimmed before it enters the prompt.
- Messages that try to ignore system instructions, reveal secrets, or bypass approvals are blocked before LLM execution.
- Blocked prompt attempts are written to the audit log with sanitized metadata.
- Semantic vector memory was intentionally deferred; the immediate priority was safety around tool execution.

Security Sequence

Lifecycle of a controlled agent action



Verification and Test Report

Checks completed after implementation

Automated Verification

- Focused test file added: backend/tests/test_security_hardening.py.
- Tests cover payload validation, policy approval rules, destructive action role denial, prompt-injection detection, and audit hash tamper detection.
- Command passed: .venv/Scripts/python.exe -m pytest RecruitmentAssist/backend/tests/test_security_hardening.py.
- Result: 8 tests passed.
- Compile check passed for all touched backend modules and the new test file.

Manual Checks Recommended

- Try candidate_delete as a recruiter and confirm it is denied.
- Try candidate_delete as manager/admin without confirmed=True and confirm approval is required.
- Try interview_schedule without confirmed=True and confirm no email is sent.
- Ask recruiter chat to ignore previous instructions and confirm the message is blocked and audited.
- Run verify_audit_chain() after several controlled actions and confirm the chain is valid.